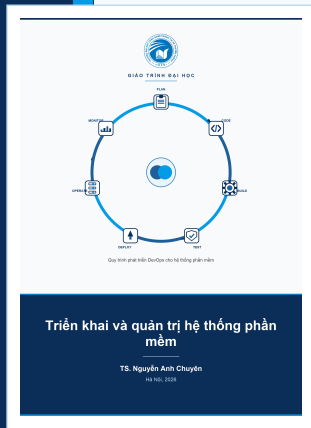




CHƯƠNG 5

Quản trị Web Server tự động & Proxy

Triển khai và quản trị hệ thống phần
mềm



Giới thiệu nội dung

Mục tiêu chương

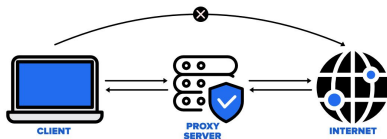
- Phân biệt forward proxy và reverse proxy; trình bày quy trình xử lý yêu cầu qua Reverse Proxy.
- So sánh cấu hình Nginx thủ công với quản lý tập trung qua Nginx Proxy Manager (NPM).
- Triển khai NPM bằng Docker Compose và cấu hình Proxy Host kèm SSL tự động (Let's Encrypt).

Nội dung chính

- 1 Proxy Server và Reverse Proxy**
- 2 Bảo mật ứng dụng web qua Proxy**
- 3 Nginx Proxy Manager: kiến trúc và triển khai**
- 4 Thực hành: đưa dịch vụ ra sau Reverse Proxy**

Vì sao hệ thống cần một máy chủ trung gian?

- **Proxy Server:** máy chủ trung gian giữa client và máy chủ đích (origin server).
- Client không giao tiếp trực tiếp với server đích – Proxy tiếp nhận, xử lý rồi mới chuyển tiếp yêu cầu.

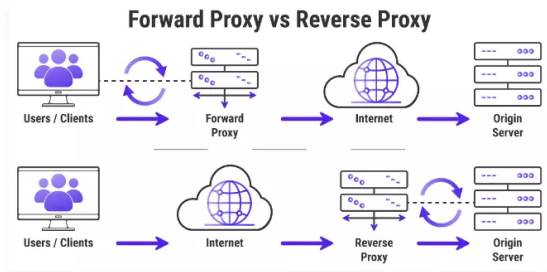


Lợi ích chính

Tăng bảo mật, kiểm soát lưu lượng, tối ưu hiệu suất, ẩn giấu thông tin nội bộ.

Hai hướng triển khai: Forward Proxy và Reverse Proxy

- **Forward Proxy:** đứng về phía **client** – đảm bảo không server đích nào giao tiếp trực tiếp với client cụ thể.
- **Reverse Proxy:** đứng trước **server đích** – đảm bảo không client nào giao tiếp trực tiếp với server đích.
- Khác biệt nhỏ nhưng quan trọng: vị trí đặt của proxy quyết định proxy đang bảo vệ ai.

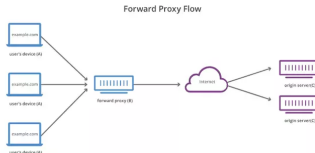


Forward Proxy: kiểm soát truy cập phía client

- Phổ biến trong mạng doanh nghiệp: kiểm soát truy cập Internet của người dùng nội bộ.
- Chức năng: lọc nội dung (web filtering), ẩn IP thực của client, ghi log truy cập.

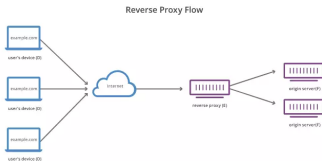
Ví dụ

Nhân viên truy cập Facebook qua Forward Proxy của công ty; proxy kiểm tra chính sách rồi mới chuyển tiếp hoặc chặn.



Reverse Proxy: năm chức năng chính trước hệ thống server

- **Load Balancing:** phân phối lưu lượng đều cho một nhóm máy chủ, tự động chuyển tải khi hỏng.
- **Tăng bảo mật:** ẩn IP thực của backend – kẻ tấn công chỉ thấy được Proxy.
- **SSL Termination:** giải mã/mã hóa TLS tại Proxy, giải phóng tài nguyên cho backend.
- **Compression, caching, rate limiting:** lưu cache gần người dùng, tăng tốc độ truy cập.



Ứng dụng Reverse Proxy trong hệ thống hiện đại

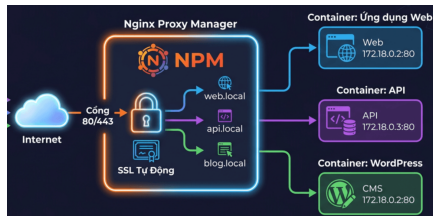
- Cho phép triển khai kiến trúc **microservices** an toàn, backend không cần lộ diện.
- Dễ dàng **scale horizontally**: thêm/bớt máy chủ phía sau mà client không hề hay biết.
- Bảo vệ backend khỏi **DDoS** và các tấn công tầng ứng dụng (layer 7).
- Giải pháp phổ biến: `Nginx`, `HAProxy`, `Traefik`, `Envoy`, Cloudflare, AWS ALB/ELB.

Quy trình xử lý một yêu cầu qua Reverse Proxy

- 1 **Tiếp nhận yêu cầu:** request đi thẳng tới Reverse Proxy, không đến trực tiếp máy chủ gốc.
- 2 **Xử lý bảo mật & lọc:** giải mã SSL/TLS, xác thực, áp dụng rate limiting/WAF, phân tích URL/Host header.
- 3 **Chuyển tiếp (Routing/Load Balancing):** chọn máy chủ nội bộ phù hợp theo thuật toán cân bằng tải.
- 4 **Nhận phản hồi:** máy chủ nội bộ xử lý xong, gửi dữ liệu trả về cho Reverse Proxy.
- 5 **Trả kết quả cho client:** có thể cache, nén dữ liệu, mã hóa lại SSL/TLS trước khi trả về – client không biết địa chỉ thực của backend.

Reverse Proxy: Single Entry Point bảo vệ hệ thống

- Nguyên tắc cốt lõi: Reverse Proxy là **điểm vào duy nhất** (Single Entry Point) của toàn bộ ứng dụng web.
- Toàn bộ lưu lượng phải đi qua Proxy trước khi tới backend – không truy cập trực tiếp máy chủ ứng dụng.
- Nhờ đó Proxy trở thành lớp bảo mật mạnh mẽ, thực thi nhiều cơ chế bảo vệ trước khi request đến được backend.



Kết hợp WAF và ẩn giấu backend

- **Kết hợp WAF:** tích hợp `ModSecurity` (tường lửa web mã nguồn mở) trên Nginx/Apache cùng bộ quy tắc **OWASP CRS**.
- OWASP CRS phát hiện tấn công chung, bảo vệ khỏi **SQL Injection (SQLi)** và **Cross-Site Scripting (XSS)** bằng cách chấm điểm bất thường (Anomaly Scoring) thay vì chỉ chặn từng sự kiện riêng lẻ.
- **Ẩn giấu cấu trúc Backend:** backend không cần public IP, chỉ giao tiếp nội bộ với Reverse Proxy.
- Kẻ tấn công chỉ nhìn thấy IP của Proxy – khó tấn công trực tiếp vào các máy chủ dịch vụ phía sau.

SSL Termination, giới hạn tốc độ và chống lạm dụng

- **Quản lý mã hóa SSL/TLS:** Proxy giải mã HTTPS, kiểm tra certificate, mã hóa lại khi chuyển tiếp đến backend; hỗ trợ HTTP/2, HTTP/3, TLS 1.3.
- **Rate limiting:** giới hạn số lượng request theo IP, theo User-Agent hoặc theo Session.

Tấn công cần phòng chống

Brute force / credential stuffing: dùng danh sách username-password bị lộ ở nơi khác để dò mật khẩu nơi khác. **API abuse:** khai thác sai mục đích hoặc điểm yếu của API để trích xuất dữ liệu hoặc gây hại hệ thống.

Từ file cấu hình thủ công đến giao diện quản trị web

- Nhiều reverse proxy phổ biến: Nginx, Traefik, Caddy, HAProxy... nhưng hầu hết yêu cầu viết config file thủ công, dài dòng, dễ sai cú pháp.
- **Nginx Proxy Manager (NPM)**: ứng dụng chạy trên Docker giúp cấu hình Reverse Proxy cho các dịch vụ trong homelab hoặc VPS.
- Tích hợp sẵn công cụ tạo chứng chỉ SSL miễn phí từ **Let's Encrypt**.
- Toàn bộ thao tác thực hiện qua giao diện web – không cần viết một dòng cấu hình Nginx nào.

Nói ngắn gọn

NPM biến việc quản lý reverse proxy từ “sửa config file, reload nginx, debug lỗi cú pháp” thành “điền form, bấm Save”.

So sánh: cấu hình Nginx thủ công và NPM

	Cấu hình thủ công	Nginx Proxy Manager
Thao tác	Viết/sửa config file, reload Nginx	Điền form trên giao diện web
SSL Let's Encrypt Rủi ro cú pháp	Chạy certbot thủ công Dễ sai khi sửa tay	Tự động cấp và gia hạn Hạn chế nhờ giao diện có kiểm soát
Tuỳ biến sâu	Toàn quyền kiểm soát	Vẫn hỗ trợ Custom Nginx config khi cần

Kiến trúc NPM: bốn thành phần chính

- **Nginx:** thành phần reverse proxy chính – nhận request HTTP/HTTPS, chuyển tiếp đến backend.
- **Giao diện quản trị web:** cấu hình proxy host, SSL, access list, user; mặc định chạy tại cổng 81.
- **Database:** lưu thông tin cấu hình – dùng SQLite hoặc MariaDB/MySQL tùy cách triển khai.
- **Let's Encrypt:** tự động cấp và gia hạn chứng chỉ SSL miễn phí.

Triển khai

Toàn bộ bốn thành phần đóng gói trong một image Docker – deploy chỉ trong khoảng 2 phút, không ảnh hưởng hệ thống host.

Triển khai NPM bằng Docker Compose

```
services:
  npm:
    image:
      ↪ jc21/nginx-proxy-manager:latest
    container_name: nginx-proxy-manager
    restart: unless-stopped
    ports:
      - "80:80"          # HTTP
      - "443:443"        # HTTPS
      - "81:81"          # Admin panel
    volumes:
      - npm_data:/data
      - npm_letsencrypt:/etc/letsencrypt
    networks:
      - proxy-network
```

- Cổng 81: giao diện admin – có thể đóng trên firewall sau khi setup xong.
- npm_data: lưu database và cấu hình proxy hosts.
- npm_letsencrypt: lưu chứng chỉ SSL.
- proxy-network: mạng dùng chung giữa NPM và các container ứng dụng – quan trọng nhất, đừng quên!

Khởi động và kiểm tra container NPM

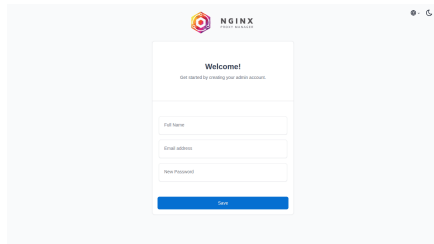
```
$docker compose up -d
```

- Container khởi động, các cổng 80/443/81 được lắng nghe theo đúng thiết lập.
- Truy cập giao diện quản trị tại `http://[IP]:81`.

```
anhchuyen@linuxserver: ~$ docker compose ps
NAME                IMAGE                                COMMAND                  SERVICE    CREATED        STATUS        PORTS
app-app-1           jcl1/nginx-proxy-manager:latest     "/init"                  app        9 minutes ago  Up 9 minutes  0.0.0.0:81->81/tcp
p, [::]:81->81/tcp, 0.0.0.0:8080->80/tcp, [::]:8080->80/tcp, 0.0.0.0:8443->443/tcp, [::]:8443->443/tcp
anhchuyen@linuxserver: ~$
```

Khởi tạo tài khoản quản trị lần đầu

- Truy cập `http://[IP]:81` lần đầu tiên sẽ hiển thị màn hình khởi tạo tài khoản quản trị.
- Tài khoản mặc định trước khi đổi: email `admin@example.com`, mật khẩu `changeme`.

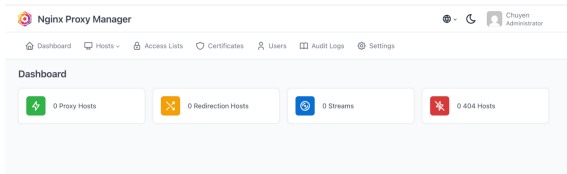


The screenshot shows the NGINX admin interface. At the top, there is a logo and the text "NGINX". Below this, a "Welcome!" message states "Get started by creating your admin account." The form contains three input fields: "Full Name", "Email address", and "New Password". A blue "Save" button is located at the bottom of the form.

Bắt buộc đổi ngay

Phải đổi email và mật khẩu mặc định ngay sau lần đăng nhập đầu tiên để tránh rủi ro bảo mật.

Giao diện quản trị Nginx Proxy Manager



- Điều hướng chính: **Hosts** (Proxy Hosts, Redirection, Streams), **Access Lists, Certificates, Users.**
- Toàn bộ thao tác thêm domain, cấu hình SSL, quản lý người dùng đều thực hiện tại đây – không cần sửa file cấu hình.

Chuẩn bị dịch vụ chạy phía sau Reverse Proxy

- Ví dụ minh họa: một website tĩnh HTML (`nginx:alpine`) và một website WordPress (WordPress + MariaDB), đều triển khai bằng Docker Compose.
- Mỗi dịch vụ khai báo container riêng, không mở port ra ngoài – chỉ giao tiếp nội bộ với NPM.
- **Bắt buộc:** tất cả container dịch vụ và NPM phải dùng chung một Docker network (ví dụ `npm_network`) để Proxy nhìn thấy được các dịch vụ.

Cách trỏ dịch vụ

Reverse Proxy trỏ đến dịch vụ bằng **tên container** (ví dụ `static-site`, `wordpress`) thay vì địa chỉ IP.

Cấu hình Proxy Host cho website tĩnh

- Vào **Hosts** → **Proxy Hosts** → **Add Proxy Host**.
- **Domain Names:** `static.example.com`; **Scheme:** `http`.
- **Forward Hostname/IP:** `static-site` (tên container); **Forward Port:** `80`.
- Bật **Cache Assets** và **Block Common Exploits**; không cần **Websockets Support**.
- Tab **SSL**: **Request a new SSL certificate**, bật **Force SSL**, nhấn **Save**.

Cấu hình nâng cao cho WordPress

- Proxy Host tương tự website
tính: `Forward Hostname/IP`
`= wordpress`,
`Forward Port = 80`.
- Vào tab **Advanced** của
Proxy Host, dán thêm cấu
hình Nginx tùy chỉnh để
WordPress nhận đúng thông
tin request gốc.

```
location / {  
    proxy_set_header Host $host;  
    proxy_set_header X-Real-IP  
        $remote_addr;  
    proxy_set_header X-Forwarded-For  
        $proxy_add_x_forwarded_for;  
    proxy_set_header  
        ↪ X-Forwarded-Proto  
        $scheme;  
}  
  
client_max_body_size 100m;
```

Hoàn tất: SSL tự động và cấu hình URL WordPress

- Tab SSL của Proxy Host WordPress: **Request a new SSL certificate** + bật **Force SSL**, tương tự website tĩnh.
- Sau khi Proxy Host hoạt động, vào **WordPress Admin** → **Settings** → **General**.
- Sửa **WordPress Address (URL)** và **Site Address (URL)** thành `https://blog.example.com`.
- Lưu lại cấu hình và xóa cache nếu website có dùng plugin cache.

Kiểm tra

Truy cập lại domain bằng HTTP để xác nhận Force SSL có tự động chuyển hướng sang HTTPS hay không.

Tổng kết chương

Những điểm cần ghi nhớ

- Proxy server là máy chủ trung gian giữa client và server đích, giúp tăng bảo mật và kiểm soát lưu lượng.
- Forward proxy đứng về phía client; Reverse proxy đứng trước server ứng dụng (cân bằng tải, bảo mật, SSL termination).
- Reverse proxy là “Single Entry Point”: kết hợp WAF chống SQLi/XSS, ẩn cấu trúc backend, giới hạn tốc độ truy cập.
- Đã triển khai NPM bằng Docker Compose và cấu hình Proxy Host cho website tĩnh và WordPress kèm SSL tự động.